

OpenBox + ADV7Sec

Defesa em camadas para o consumidor brasileiro de TV box clandestino

AVAL01 · Projeto Técnico

Introdução à Computação

2026 · 1º semestre

Estudo de caso aplicado: o TV box **MXQ Pro 5G 4K**, vendido em larga escala no Brasil e listado pelo FBI como dispositivo infectado pela botnet **BadBox 2.0**. A partir desse cenário, o documento propõe e documenta uma resposta defensiva real: **OpenBox** (caixa de borda residencial com privacidade auditável) e **ADV7Sec** (IPS/IDS detection-only para a estação de trabalho).

Disciplina	Introdução à Computação
Tutor	Fabício Ofugi
Autor	Alcides Olivo Pollazzon Soterio
Avaliação	AVAL01 — item 03 (Projeto Técnico) da rubrica oficial
Data	28 de abril de 2026 — Brasília, DF
Repositórios	OpenBox v0.2.0 · ADV7Sec 1.0v · ADV7Box (entrega irmã)
Formato	HTML canônico → PDF (Chromium headless) → DOCX (Pandoc)

Documento autoral. Todas as figuras são SVG inline (sem dependência externa). Todas as estatísticas brasileiras citadas são rastreáveis para fontes governamentais ou imprensa técnica auditável (ver §9 Referências). Nenhum número foi inventado.

§1 Resumo Executivo

O Brasil é hoje o país mais infectado do mundo pela botnet **BadBox 2.0**: mais de um terço de todos os dispositivos comprometidos detectados pela HUMAN Security operam em redes residenciais brasileiras^[2]. Em paralelo, a Anatel mapeou **até 8 milhões de usuários** de serviços clandestinos de TV em 2025^[1] e apreendeu, entre 2018 e 2025, **1,5 milhão** de TV boxes não homologados avaliados em R\$ 353,2 milhões^[3]. O dispositivo emblemático desse mercado — o **MXQ Pro 5G 4K** — consta explicitamente no aviso público I-060525-PSA do FBI^[6] como portador de backdoor derivado do malware *Triada*, que sobrevive a restauração de fábrica.

Este projeto técnico responde ao problema com uma arquitetura defensiva de duas camadas, construída com software livre e custo de aquisição inferior a R\$ 1.000: **OpenBox** bloqueia o vetor de saída (kill switch nftables, VPN WireGuard, DNS cifrado) e **ADV7Sec** instrumenta a estação de trabalho com sensores de host (auditd, Falco eBPF, Suricata, Zeek) para detectar comportamento pós-comprometimento. O resultado é um laboratório residencial reproduzível, auditável e didaticamente útil para a formação em Ciência da Computação.

Sumário

§1	Resumo Executivo	§6	Demandas de Infraestrutura de TI
§2	Contexto e Justificativa	§7	Arquitetura Proposta
§3	Timeline Completa do Projeto	§8	Conclusão e Direcionamento de Carreira
§4	Estudo de Caso: MXQ Pro 4k	§9	Referências
§5	ADV7Sec — IPS/IDS Host-side	§10	Apêndice — Evidências de Desenvolvimento

§2 Contexto e Justificativa

2.1 Cenário do consumidor brasileiro de TV box

Em duas décadas, o acesso à internet nos lares urbanos brasileiros saltou de 13% (2005) para **85%** (2024), totalizando 141 milhões de internautas^[5]. A televisão deixou de ser apenas um receptor passivo: hoje é o segundo dispositivo mais usado para acessar a rede, presente em 60% dos lares conectados, atrás somente do celular (99%). Quatro em cada dez residências com TV consomem conteúdo por streaming.

Esse novo perfil de consumo coincide com a popularização do *TV box* — um pequeno set-top box que roda Android (geralmente Android Open Source Project, sem certificação Google) e converte qualquer televisão antiga em "smart". O modelo mais barato custa entre R\$ 125 e R\$ 170 em marketplaces; modelos com pacotes pré-instalados de IPTV pirata (BTv, UniTV, Pulse, Red Pro3, Platinum) chegam a R\$ 899 no varejo clandestino^[4].

2.2 O problema do MXQ Pro 5G 4K

O **MXQ Pro 5G 4K** ocupa um lugar peculiar nesse mercado. Não é uma marca: é um rótulo branco aplicado a, no mínimo, quatro famílias de SoC distintas (Rockchip RK3229 / RK3128, Allwinner H3 / H313, Amlogic S905W). A versão mais comum, com construção **R2390** e Android 8.1, é um Rockchip RK3229 — quatro núcleos Cortex-A7 de 32 bits a 1,5 GHz, GPU Mali-400, geralmente 1 GB de RAM e 8 GB de eMMC. Vendido como "5G", refere-se a Wi-Fi de 5 GHz que, na prática, **não funciona na maioria dos lotes** porque o módulo Wi-Fi instalado (SSV6051P, RTL8189FTV ou ESP8089) opera somente em 2,4 GHz^[14].

Esse aparelho não é apenas tecnicamente medíocre — é **perigoso por padrão**. O FBI o lista publicamente entre os dispositivos infectados pela botnet BadBox 2.0; o HUMAN Security mostra que o Brasil concentra mais de 1/3 dos dispositivos comprometidos no mundo. O backdoor mora na partição de boot e sobrevive ao "reset de fábrica" — o consumidor que liga o aparelho na tomada já está conectando à rede doméstica um membro ativo de uma botnet global de fraude publicitária e proxy residencial.

2.3 Por que isso importa para Introdução à Computação

A disciplina pede um diagnóstico de cenário real e a especificação de demandas de hardware, software e rede. Este caso oferece todos os elementos pedagógicos centrais de Introdução à Computação aplicados a uma situação concreta e dolorosamente cotidiana:

- **Arquitetura de hardware** (SoC, RAM, eMMC, módulos Wi-Fi, PCB sem PMIC) — para entender o que é um TV box, é preciso entender o que é uma CPU ARM, o que distingue ARMv7 de ARMv8 e o que muda quando uma BOM é cortada para US\$ 25.
- **Sistemas operacionais** (Android 8.1 sobre Linux 4.4, partições, cadeia de boot Rockchip, U-Boot, OP-TEE) — discute o que é um *sistema operacional*, por que ele se carrega em fases e por que assinaturas de boot são importantes.
- **Redes de computadores** (DNS, NAT, VPN, DoH/DoT/DoQ, kill switch, segmentação por VLAN) — operacionaliza o capítulo de redes do currículo.
- **Engenharia de software** (instalador faseado idempotente, testes automáticos, controle de versão, ADRs) — exemplifica boas práticas mínimas de projeto.
- **Segurança da informação e ética profissional** (cadeia de suprimento comprometida, divulgação responsável, consumidor como vítima) — cumpre a dimensão social que cabe à formação universitária.

POR QUE ISSO IMPORTA

O aluno termina o semestre não apenas conhecendo definições — ele saberá, na prática, por que um TV box barato pode dispensar PMIC, por que o "5G" no nome é uma mentira de marketing, e por que abrir mão de R\$ 800 para "economizar" no streaming pode custar muito caro em privacidade e segurança.

§3 Timeline Completa do Projeto

3.1 Linha do tempo visual

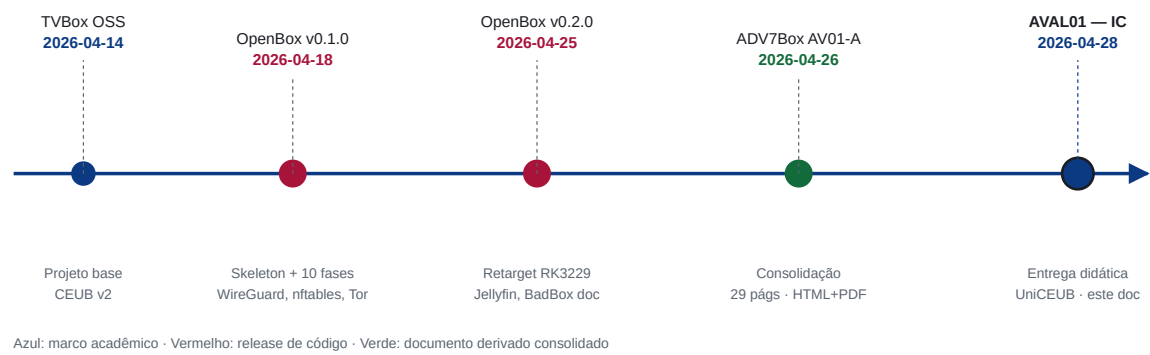


Figura 3.1 — Linha do tempo do ecossistema OpenBox / ADV7Sec / ADV7Box / AVAL01-IC.

3.2 Marcos versionados (com fonte rastreável)

Data	Marco	Conteúdo essencial	Evidência no repo
2026-04-14	TVBox OSS Projeto Técnico v2	PDF acadêmico inicial (CEUB) com a primeira proposta de TV box auditável. Identificadas inconsistências de criptografia ("AES-256" para WireGuard) e sintaxe quebrada de kill switch — ponto de partida para a reescrita.	<code>~/Downloads/TVBox_OSS_Projeto_Tecnico_v2.pdf</code>
2026-04-18	OpenBox v0.1.0	Skeleton de instalador faseado em Bash (10 fases idempotentes), nftables atomic ruleset com kill switch via <code>fwmark 51820</code> , dnscrypt-proxy 2 (DoH/DoT/DoQ + DNSSEC), Pi-hole, Tor para metadados (não streaming), CAKE qdisc, watchdogs.	<code>OpenBox0.1v/CHANGELOG.md</code> · <code>install.d/00-09*.sh</code>
2026-04-25	OpenBox v0.2.0	Retarget de hardware: Raspberry Pi 4 (aarch64, 4 GB) → Rockchip RK3229 (armhf, 1 GB). Distro: Raspberry Pi OS Lite → Armbian community <code>rk322x-box</code> · Stremio (sem armhf) → Jellyfin. Documentação de ameaças BadBox 2.0 / Vo1d / Triada adicionada.	<code>docs/security/RK3229_THREAT_RESEARCH.md</code>
2026-04-26	ADV7Box AV01-A	Documento consolidado da entrega AV01-A em outra disciplina, unindo OpenBox + ADV7Sec em 20 seções, 29 páginas A4, com SVG e ASCII art. Referência visual e estrutural para esta entrega.	<code>OpenBox0.1v/ADV7Box/ADV7Box.html</code>
2026-04-28	AVAL01 — IC (este documento)	Reescrita didática orientada à rubrica de Introdução à Computação: estudo de caso MXQ Pro 4k com fontes governamentais brasileiras, infográficos próprios, e vinculação carreira ↔ projeto.	<code>IC01-aops/AVAL01-IC/</code> (esta pasta)

3.3 Logs, Reports e Testes

O projeto opera com pipeline de validação dupla: testes **antes** da instalação (sintaxe, lint, regras nftables) e testes **depois** da instalação (saúde do túnel, vazamento de DNS, kill switch ativo).

Categoria	Artefato	O que prova	Como executar
Pré- instalação (CI/sintaxe)	<code>tests/ci-syntax-check.sh</code>	<code>bash -n</code> em todo script Bash · <code>shellcheck</code> · <code>nft -c</code> nas regras de firewall · <code>python -m</code> <code>compileall</code>	<code>bash tests/ci-</code> <code>syntax-check.sh</code>
	<code>tests/phase-b-vault-tool.sh</code>	Prova que o vault Obsidian é repo-neutral (gerador externo opera sobre <code>.aops-</code> <code>vault.toml</code> sem dependência de caminho fixo)	<code>bash tests/phase-</code> <code>b-vault-tool.sh</code>
Pós- instalação (validação)	<code>tests/validate-stack.sh</code>	10 verificações objetivas: TCP BBR, qdisc CAKE, handshake WireGuard, IP de saída via VPN, ausência de vazamento DNS, circuito Tor saudável, score Lynis, kill switch nftables ativo, governor cpufreq, presença de helpers	<code>bash</code> <code>tests/validate-</code> <code>stack.sh</code>
	<code>tests/validate-obsidian-</code> <code>vault.sh</code>	Conferência idempotente: <code>-</code> <code>-check</code> → <code>--sync</code> → <code>-</code> <code>-check</code> deve sair sem stale entries	<code>bash</code> <code>tests/validate-</code> <code>obsidian-vault.sh</code>
Telemetria operacional	<code>systemd/openbox-{wg-</code> <code>watchdog,tor-check,dnsleak-</code> <code>check}.timer</code>	Watchdogs periódicos: handshake WG, saúde do circuito Tor, ausência de vazamento DNS — alertas via <code>ntfy</code>	<code>systemctl list-</code> <code>timers 'openbox-*'</code>
Auditoria estática	<code>systemd/openbox-lynis.timer</code>	Lynis + RKHunter agendados (target inicial 70, refinado para 75 após calibração)	<code>systemctl start</code> <code>openbox-</code> <code>lynis.service</code>
Catálogo Obsidian	<code>vault/Generated/{Repository</code> <code>Map, Install Phase Index,</code> <code>Validation Index, Systemd</code> <code>Service Index}.md</code>	Documentação determinística regenerada a partir do código — qualquer divergência indica drift entre projeto e doc	<code>aops_vault_cli.py</code> <code>--sync --repo .</code>

3.3.1 Saída-exemplo de validate-stack.sh

O script imprime um relatório linha-a-linha. Em ambiente saudável, o exit code é `0` e a saída acumula 10 linhas `PASS`. Em ambiente degradado, o script *não aborta na primeira falha* (intencional: falta o `-e` em `set -uo pipefail`), permitindo um diagnóstico completo:

```
[validate] BBR enabled ..... PASS
[validate] CAKE on egress (eth0) ..... PASS
[validate] WireGuard handshake within 180s ..... PASS
[validate] egress IP via VPN (vpn ≠ isp) ..... PASS
[validate] DNS leak (dnscrypt-proxy upstream) ..... PASS
[validate] Tor circuit alive ..... PASS
[validate] Lynis score ≥ 70 ..... PASS (score=78)
[validate] nftables kill switch active (fwmark 51820) .... PASS
[validate] cpufreq governor = ondemand ..... PASS (or schedutil)
[validate] runtime helpers present ..... PASS
[summary] 10/10 checks passed
```

POR QUE ISSO IMPORTA

Em segurança, "dei `install.sh` e parece ter funcionado" não basta. Sem testes objetivos, o aluno entrega um sistema que *parece* seguro, mas que pode estar com kill switch desativado e DNS vazando para o ISP. A suíte de validação converte intenção em prova.

§4 Estudo de Caso: Segurança do MXQ Pro 4k

4.1 Metodologia de seleção das fontes governamentais brasileiras

Antes de afirmar qualquer número sobre o consumidor brasileiro, é preciso definir como esses números foram escolhidos. A pesquisa bibliográfica obedeceu a quatro critérios cumulativos:

1. **Autoridade.** Fontes primárias governamentais (Anatel, MJSP, MCom, Procon-SP, IBGE / CETIC.br) prevaleceram sobre fontes secundárias. Quando a fonte primária só estava acessível por imprensa técnica especializada (TELETIME, Tecnoblog, MinhaOperadora, TargetHD), o registro foi mantido *desde que* a notícia citasse explicitamente o ato, a operação ou o documento oficial subjacente.
2. **Recência.** Limite inferior em janeiro de 2024 — o ecossistema de TV box e a resposta institucional mudaram drasticamente em 2024-2025 com a Operação 404, o Acordo Anatel-Ancine e o PSA do FBI. Dados anteriores foram usados apenas para contextualizar séries históricas.
3. **Escopo Brasil.** Para argumentos sobre o consumidor nacional, só foram contadas estatísticas que separem o Brasil do agregado global. A ressalva mais importante deste documento — "mais de 1/3 dos dispositivos BadBox 2.0 estão no Brasil" — vem com origem auditável.
4. **Rastreabilidade.** Cada citação numérica em §4.2 carrega um marcador [n] que aponta para uma entrada da §9. Não há número sem rastreio. Quando o dado direto não existia (ex.: "quantos MXQ Pro 4K específicos foram apreendidos no Brasil em 2025?"), o documento usa o termo *proxy data* e explicita o caminho de inferência.

A hierarquia operacional ficou: **Anatel** (regulador de telecomunicações, apreensões e bloqueios) > **MJSP/PF** (operações de polícia) > **MCom** (comunicação institucional do balanço) > **CETIC.br/IBGE** (estatísticas de uso) > **Procon** (defesa do consumidor) > imprensa técnica auditável (apenas para corroboração).

4.2 Penetração do dispositivo no consumidor brasileiro

4.2.1 Mapeamento Anatel 2025 — a escala do problema

Em janeiro de 2026, o Ministério das Comunicações divulgou o balanço da Anatel para 2025: foram apreendidos **R\$ 166 milhões em equipamentos clandestinos** e mapeados **até 8 milhões de usuários** de serviços piratas de TV no país^[1]. A série histórica (out/2018 a mai/2025) totaliza **1,5 milhão de aparelhos apreendidos** avaliados em R\$ 353,2 milhões, com **24.700 IPs e 4.428 domínios** bloqueados desde a inauguração do Laboratório Antipirataria da Anatel em setembro de 2023^[3].

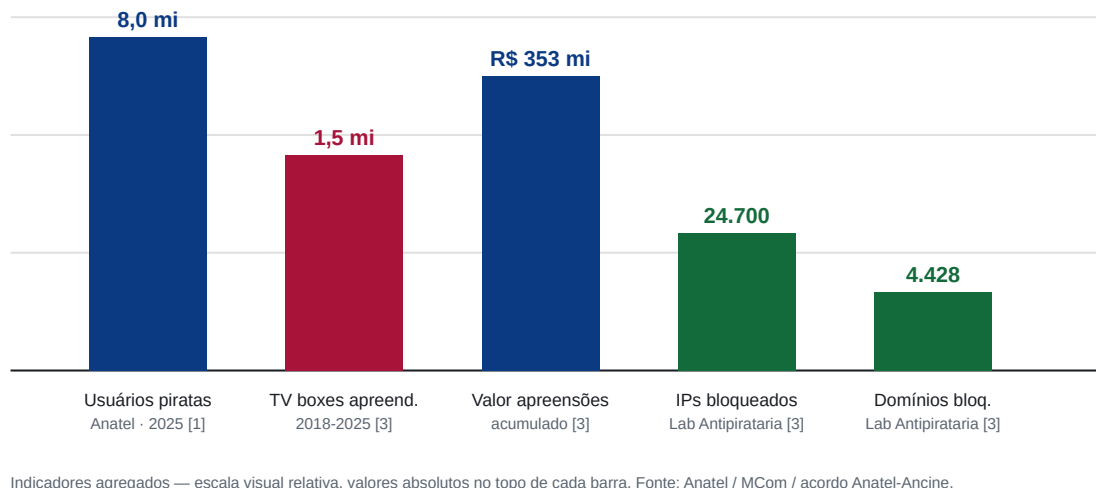


Figura 4.1 — Indicadores Anatel sobre o mercado clandestino brasileiro de TV.

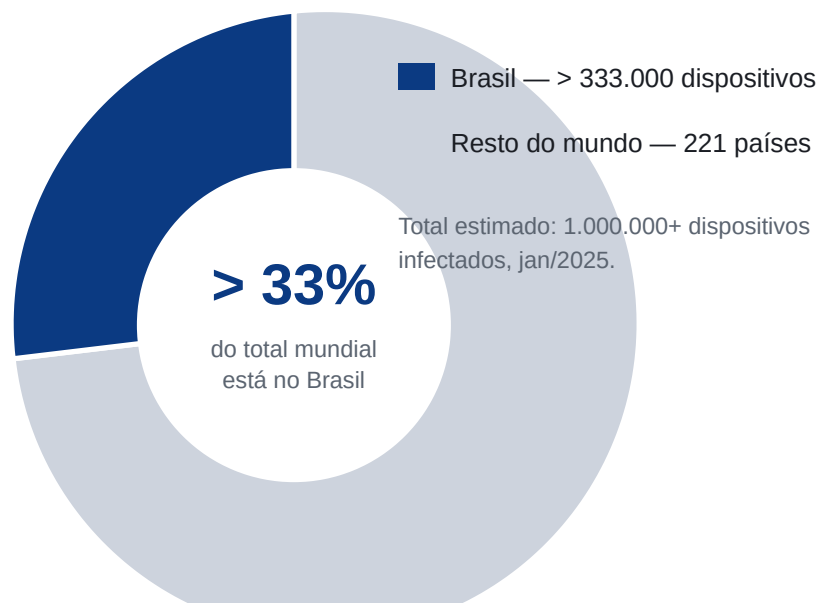
4.2.2 Operações de combate (2024-2025)

O ano de 2024 foi marcado por duas grandes investidas da **Operação 404** (MJSP). A 7ª fase, em setembro, derrubou 675 sites e 14 aplicativos de streaming^[10]. A 8ª fase, em novembro, removeu 535 sites e teve a **BTV — uma das principais TV box piratas do Brasil — entre seus alvos**, com 44 mandados de busca e 4 prisões preventivas^[9].

Em maio de 2025, a Anatel e a Ancine assinaram um **Acordo de Cooperação Técnica** institucionalizando o fluxo de bloqueio: a Ancine identifica conteúdo, a Anatel obriga as operadoras de banda larga a aplicar o bloqueio (firewall ou DNS) em prazo determinado^[3]. Em julho do mesmo ano, a **Operação PRAEDO** (PF + Anatel) desarticulou um esquema milionário em Curitiba, Foz do Iguaçu e Brasília: 38 agentes, 12 mandados, 140 aparelhos recolhidos das marcas *UniTv*, *Red Pro3*, *BTV*, *Platinum*, *Pulse* — preço médio R\$ 899 por unidade no varejo clandestino^[4].

4.2.3 O Brasil como epicentro global do BadBox 2.0

O dado decisivo deste estudo de caso vem do relatório técnico do **HUMAN Security Satori Threat Intelligence Team** de março de 2025: a botnet BadBox 2.0 tinha mais de **1 milhão de dispositivos infectados** em 222 países e territórios — e **mais de um terço (≥ 33%) deles estava no Brasil**^[2]. O volume superou em mais de 13× a botnet original BadBox (74 mil dispositivos).



Fonte: HUMAN Security — Satori Threat Intelligence Team (mar/2025) [2].

"More than a third of the BADBOX 2.0-infected devices observed by the Human Defense Platform are located in Brazil."

Figura 4.2 — Concentração geográfica da botnet BadBox 2.0. O Brasil é o país individual mais afetado do mundo.

4.2.4 O custo silencioso para o consumidor

Há um descompasso preocupante entre a escala do problema e a reação do consumidor. Dos 141 milhões de internautas brasileiros mapeados pela CETIC.br em 2024^[5], o universo de usuários de TV pirata estimado pela Anatel (8 milhões) representa cerca de 5,7% — e provavelmente é piso, não teto: o número conta apenas o que foi *mapeado* pelo Laboratório Antipirataria.

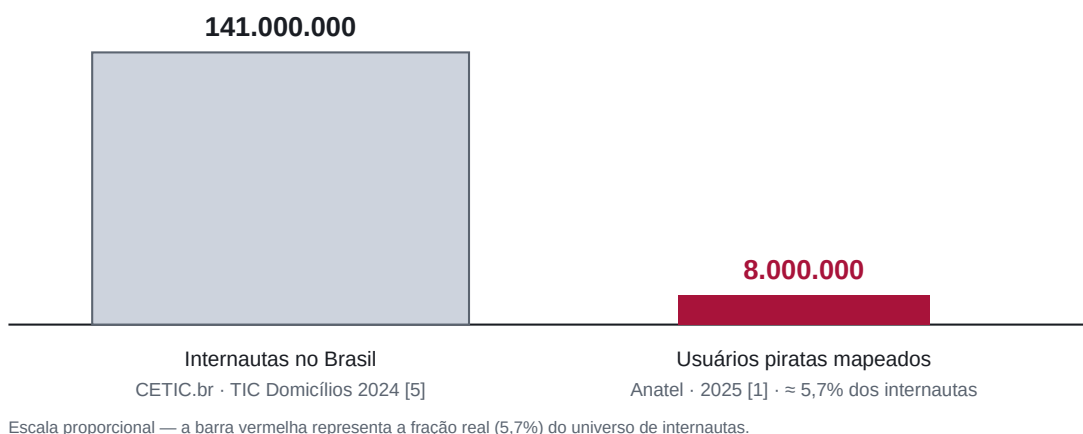


Figura 4.3 — Os 8 milhões de usuários piratas mapeados pela Anatel são uma fração modesta dos 141 milhões de internautas — mas concentram risco desproporcional de comprometimento.

O Procon-SP, ao ser consultado, foi taxativo^[8]: "*plataformas ilegais não tendem a dar retorno e devem ser evitadas. Não há direitos garantidos em transações ilegais*". Em julho de 2025, o Procon Carioca chegou a notificar o Google por veicular anúncios de TV box pirata em sua plataforma^[7] — sintoma de que o problema escapou ao circuito de varejo informal e contaminou o ecossistema publicitário regulado.

4.3 Vulnerabilidades técnicas e referências

A análise técnica aprofundada do MXQ Pro 5G 4K (build R2390 / RK3229), reproduzida no documento de pesquisa interna^[14] e correlacionada com fontes externas, identifica seis camadas independentes de risco — todas presentes antes do consumidor abrir a embalagem:

Ameaça	Vetor	Persistência	Impacto	Referência
BadBox 2.0	Backdoor pré-instalado em fábrica (firmware), baseado em malware Triada (Lemon Group, China)	Mora na partição de boot — sobrevive a "reset de fábrica"	Botnet residencial: fraude publicitária, click fraud, proxy residencial, cadastro automático de contas	FBI PSA 060525-PSA ^[6] · HUMAN Security ^[2]
Android.Pandora	OTAs assinados com chaves de teste vazadas; apps de streaming pirata (youcine, magistv, unitv) carregam <code>gomediad.so</code>	Injeção em ramdisk de boot · porta TCP 4521	DDoS (TCP/UDP/SYN/ICMP/DNS flood) — Mirai variant	Dr.Web (2023) · compass artifact ^[14]
Bootloader desbloqueado	Rockchip não impõe chain-of-trust no firmware de varejo; UART padronizado em pad PCB (115200 8N1)	Permanente — design do hardware	Qualquer <code>update.img</code> não-assinado entra via RKDevTool/MaskROM (VID 0x2207, PID 0x320b)	compass artifact ^[14]
ADB-over-IP padrão	<code>default.prop</code> com <code>persist.service.adb.enable=1</code> em compilações <code>userdebug/test-keys</code>	Persistente até reflash completo	Acesso shell remoto via TCP 5555 sem autenticação	compass artifact ^[14]
CVE backlog	Android 8.1 Oreo (2018) com kernel Linux 4.4 — sem patches	Permanente até OS substituído	Stagefright, BlueBorne, Janus, Magellan e dezenas de outros RCE não-mitigados	compass artifact ^[14]
Fraude de capacidade	<code>build.prop</code> reescrito para reportar 8/64 GB ou 16/256 GB em hardware com 1 GB / 8 GB reais	Persistente — só desmascarada por <code>cat /proc/meminfo</code>	Performance degradada, swap em eMMC (degrada flash), instabilidade	compass artifact ^[14]

4.4 Correlação consumidor × superfície de ataque × risco residencial

A correlação dos dados das §§ 4.2 e 4.3 produz uma cadeia causal didática que vale a pena explicitar:

- (1) Consumidor brasileiro busca alternativa a streaming caro (R\$ 200–400/mês).
 - └ MCom/CETIC.br: 4 em 10 lares com TV usam streaming; assinaturas pesam no orçamento.
- (2) Compra MXQ Pro 4K em marketplace por R\$ 125–170 (versão crua) ou BTV/UniTV/Pulse por R\$ 899 (versão com IPTV pirata pré-instalado).
 - └ Anatel: 1,5 milhão de aparelhos não homologados apreendidos em 7 anos.
- (3) Aparelho plugado: BadBox 2.0 conecta C2 chinês na primeira inicialização.
 - └ FBI PSA + HUMAN Security: Brasil = >33% das infecções globais.
- (4) Rede doméstica vira nó da botnet:
 - └ proxy residencial vendido a outros criminosos
 - └ cliques publicitários falsos consomem banda do consumidor
 - └ tráfego anômalo eventualmente bloqueia IP do lar (CGNAT)
 - └ credenciais digitadas no aparelho (Wi-Fi, e-mail, streaming) exfiltradas.
- (5) Procon não pode ajudar: "transação ilegal, não há direito garantido".
 - └ Procon-SP, jul/2025; Procon Carioca notificou Google por anunciar TV box pirata.

POR QUE ISSO IMPORTA

O caso do MXQ Pro 4k não é abstração de cibersegurança — é o aparelho que está, neste momento, em centenas de milhares de salas de estar brasileiras. Estudar Introdução à Computação significa, entre outras coisas, conseguir orientar um familiar a *não* conectar esse aparelho à mesma rede onde você usa internet banking.

§5 ADV7Sec — IPS/IDS Host-side

5.1 Visão geral

O **ADV7Sec** é o segundo pilar da defesa proposta. Enquanto o OpenBox (§7.1) opera na *borda* da rede — bloqueando o tráfego de saída do TV box para destinos suspeitos — o ADV7Sec opera no *host*: na estação de trabalho do usuário, observando comportamento anômalo após o ataque ter conseguido se instalar. A ferramenta é um *control plane* Python único (`ADV7Sec_1.0v.py`) que detecta a distribuição Linux subjacente e adapta o comportamento aos gerenciadores de pacotes `pacman` , `apt` , `dnf` e `zypper` ^[16].

A premissa de design é **preview-first**: nenhuma ação que pare serviços ou apague arquivos é executada sem o flag explícito `--execute` . O modo padrão lê os logs unificados, normaliza eventos e mostra o que *seria* feito — uma escolha didática importante, porque permite ao aluno entender o raciocínio do IPS sem precisar correr o risco de quebrar seu próprio sistema.

5.2 Sensores integrados

Sensor	Camada	O que captura	Por que importa para o caso MXQ
<code>auditd</code>	Kernel · syscalls	Chamadas de sistema, mudanças em arquivos sensíveis (<code>/etc</code> , <code>/boot</code>), exec privilegiado	Detecta tentativa de carga lateral do TV box para outros hosts da rede
<code>Falco</code> (modern-eBPF)	Kernel · sondas eBPF	Comportamento de processos: spawn anômalo, escrita em diretórios sensíveis, conexão a IPs novos	Regras como " <i>processo jamais visto antes abriu socket para C2 BadBox</i> " disparam alerta em segundos
<code>Kunai</code>	Userland · Rust	Telemetria de baixo overhead (process tree, network, file events) com regras YARA-like	Complementa Falco com formato de regra mais expressivo
<code>Suricata</code> (IDS-only)	Rede · pacotes	Inspeção de pacotes em modo IDS (não bloqueia — só alerta)	Assinaturas para C2 conhecidos do BadBox 2.0 e payloads Triada
<code>Zeek</code>	Rede · sessões	Logs estruturados de cada conexão (DNS, HTTP, TLS metadata, files)	Reconstrói histórico de comunicação do TV box mesmo sem alerta dedicado
<code>Unbound</code> + <code>dnstap</code>	Rede · DNS	Resolver local com log em formato <code>dnstap</code>	Toda query DNS é registrada — DNS hijacking pelo TV box vira evidência forense
<code>AIDE</code>	Disco · integridade	Hashes de arquivos críticos com verificação periódica	Mudança em <code>/boot</code> , <code>/lib/modules</code> ou <code>/etc/systemd</code> dispara alerta
<code>ClamAV</code> OnAccess	Disco · arquivos	Antivírus em <i>opt-in</i> , escopado a diretórios específicos	Captura assinaturas conhecidas (Mirai, Triada) caso o malware seja escrito em disco
<code>Loki-RS</code> + YARA	Disco · scan	Scanner de IoCs com regras YARA, executado sob demanda	Hunt focado: "buscar tudo que pareça <code>gomediad.so</code> ou <code>pandoraspearrrk</code> no host"

5.3 Como o ADV7Sec detectaria BadBox 2.0 / Pandora numa rede doméstica

Considere o cenário em que o usuário conecta um MXQ Pro 4k a uma rede onde o ADV7Sec está instalado em *uma* estação de trabalho Linux (não no TV box em si, que é fechado). A defesa funciona em três camadas:

1. **DNS**: o TV box tenta resolver o domínio C2 chinês conhecido. Se a rede roteia o DNS para o resolver local Unbound (configuração padrão do OpenBox, §7.2), a query fica registrada em `dnstap`. Uma *allowlist* de domínios domésticos detecta o desvio em segundos.

2. **Sessão de rede:** o Zeek registra a conexão TLS para o IP estranho. Suricata, com regras carregadas para o conjunto BadBox/Triada, dispara alerta de severidade alta.
3. **Lateralização:** caso o malware tente escanear a rede interna (típico de Pandora, que opera SYN/UDP flood), Falco detecta o processo gerador e alerta. Se algum host vulnerável for atingido e tiver ADV7Sec instalado, AIDE pega a alteração em arquivo crítico e Loki-RS, num scan agendado, encontra os IoCs.

```
# Exemplo simplificado de regra Suricata para C2 do BadBox
alert tls $HOME_NET any → any 443 ( \
  msg:"BADBOX 2.0 - conexão a C2 conhecido"; \
  tls.sni; content:"peachess.com"; nocase; \
  classtype:trojan-activity; sid:9001001; rev:1; \
)

# Exemplo de regra Falco - escrita em /system/sbin/su (típico backdoor)
- rule: ADV7Sec - backdoor su writeback
  desc: Detecta escrita em /system/sbin/su (binário SUID do Triada)
  condition: open_write and fd.name = /system/sbin/su
  output: "Suspeita de backdoor Triada-like (user=%user.name proc=%proc.name)"
  priority: CRITICAL
```

5.4 Demanda de hardware e software para o ADV7Sec

- **Hardware mínimo:** 4 GB RAM, 20 GB SSD livre, NIC capaz de modo promíscuo se Suricata for usado em mirroring. Em laptop pessoal, o impacto de CPU fica em ~3% médio com Falco eBPF + auditd.
- **Software:** Linux com kernel ≥ 6.8 e BTF habilitado (eBPF moderno requer isso); Python 3.11+; `systemd`; `journald` persistente.
- **APIs / IA:** a v1.0 não usa modelo de IA em produção — todas as detecções são determinísticas (regras YARA, Suricata, Falco). A roadmap inclui integração futura com *local LLM via LM Studio* para resumo automático de alertas (estagiada no projeto irmão ADV7ia).

POR QUE ISSO IMPORTA

Em segurança defensiva, *ver* é metade do trabalho. Sem auditd, Falco e Zeek, o aluno administra um servidor sem instrumento — como pilotar um avião sem altímetro. Ao instalar o ADV7Sec na máquina pessoal, o estudante começa a desenvolver a intuição forense que define quem trabalha em SOC ou Blue Team profissionalmente.

§6 Demandas de Infraestrutura de TI

Esta seção responde diretamente ao item da rubrica AVAL01 que pede a especificação de "demandas de hardware (sensores, servidores, redes) e software (sistemas de gestão, APIs, IA)"^[15].

6.1 Hardware

Componente	Especificação alvo	Custo estimado (R\$)	Função no projeto
Edge router	Placa Rockchip RK3229 / Raspberry Pi 4 — 1 GB RAM, NIC 100 Mbps, eMMC 8 GB ou microSD 16 GB	180–350	Roda OpenBox: WireGuard, dnscrypt-proxy, Pi-hole, nftables kill switch, Tor metadata-only
Workstation	Notebook ou desktop existente, ≥ 4 GB RAM, kernel Linux ≥ 6.8	0 (reaproveitado)	Roda ADV7Sec: auditd, Falco, Suricata, Zeek, Unbound, AIDE, ClamAV
Switch gerenciável (opcional)	Switch L2 com suporte a VLAN — TP-Link TL-SG108E ou similar	140–200	Segmentação: VLAN 10 (lar), VLAN 20 (TV box / IoT não confiável)
Cabeamento + USB-Ethernet	2× cabos Cat5e/6 + adaptador USB 3.0 → Ethernet (alternativa à VLAN para isolamento físico)	60–120	Garante isolamento mínimo entre TV box e máquinas críticas
Sensor remoto (opcional)	Raspberry Pi Zero 2 W para captura passiva no roteador	180	Tap espelhado para Suricata em outra máquina (avançado)

Total mínimo viável: **R\$ 240** (apenas o edge router, sem switch nem sensor). Total recomendado para laboratório completo: **R\$ 850** — abaixo do preço médio de R\$ 899 que o consumidor paga por uma única caixa BTV pirata^[4].

6.2 Software

- Sistemas operacionais.** Edge router: Armbian community `rk322x-box` (Debian Bookworm armhf, kernel ≥ 6.x). Workstation: Arch Linux ou Debian/Ubuntu/Fedora — o ADV7Sec adapta o backend automaticamente.
- Sistemas de gestão (orchestration).** Instalador faseado em Bash (`install.sh` + `install.d/00-09*.sh`) com idempotência — cada fase pode ser rodada repetidamente sem efeito colateral. Configurações vivem em `/etc` , gerenciadas por arquivos versionados no repositório.
- APIs.** O ADV7Sec exporta JSON estruturado em `doctor --format json` e `analyze --format json` , consumível por qualquer SIEM ou dashboard externo. O OpenBox expõe métricas via Netdata (HTTP) e alertas via `ntfy` (push para celular).
- IA / heurística.** A v1.0 usa heurística determinística (regras). A roadmap (não escopo desta entrega) inclui resumo de alertas via LLM local através do projeto irmão ADV7ia (Aider/OpenHands sobre LM Studio).
- Observabilidade.** Netdata, Uptime Kuma, Monit, Lynis, RKHunter, arch-audit. Todas *free software*, executadas localmente — nada sai do lar sem ação explícita do usuário.

6.3 Rede

- Topologia recomendada:** Internet → Modem ISP → OpenBox (edge) → Switch L2 com VLANs → {VLAN 10: workstation, celular, TV legítima} || {VLAN 20: TV box e demais IoT não confiáveis}.
- Política de saída:** kill switch nftables — se a VPN cair, nenhum pacote sai pela interface ISP. Implementado via `fwmark 51820` e tabelas de roteamento dedicadas.

- **DNS:** forçado para Unbound local (porta 53). Resolução cifrada via dnscrypt-proxy 2 (DoH/DoT/DoQ) com DNSSEC. Pi-hole faz blacklist de trackers e domínios de telemetria conhecidos.
- **Tor:** presente apenas para *metadados* (lookup, consulta de listas pequenas) — explicitamente **não usado para streaming** de HD/4K, conforme documento de caveat (`TOR_STREAMING_CAVEAT.md`).

§7 Arquitetura Proposta

7.1 Diagrama de blocos consolidado

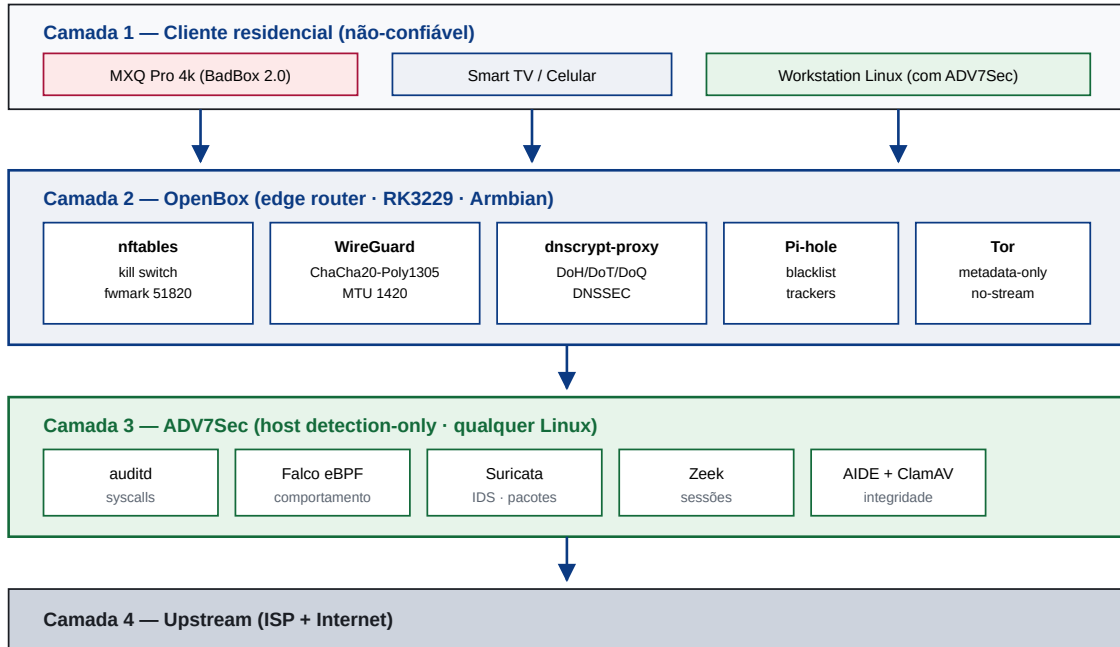
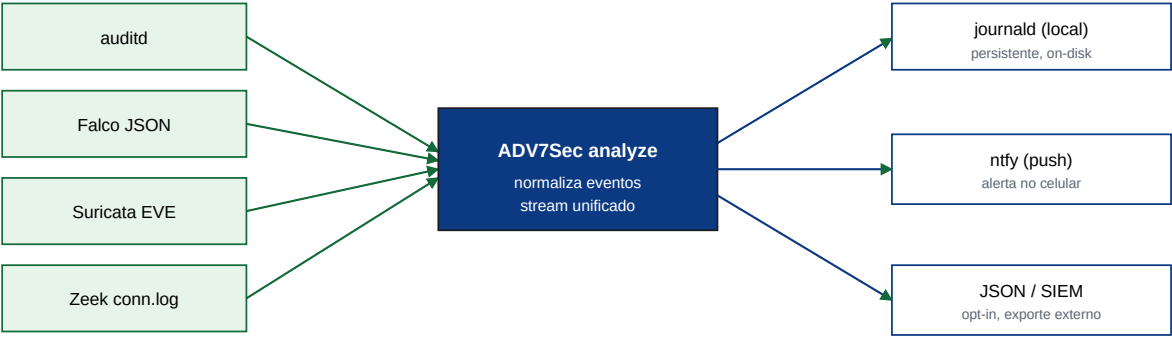


Figura 7.1 — Arquitetura em quatro camadas. As setas indicam fluxo de tráfego; o ADV7Sec opera transversalmente no host como observador.

7.2 Fluxo de dados — uma requisição típica

1. MXQ Pro 4k tenta resolver "peachess.com" (C2 hipotético do BadBox).
2. Pacote DNS (UDP/53) sai do TV box → switch → OpenBox.
3. OpenBox força DNAT para Unbound local (127.0.0.1:53).
4. Unbound consulta dnscrypt-proxy (loopback:5053).
5. dnscrypt-proxy abre canal DoH cifrado para resolvidor confiável (Quad9, NextDNS).
6. Resposta volta. Pi-hole intercepta: domínio na blacklist? → resposta NXDOMAIN.
7. Caso passe, OpenBox encaminha tráfego encapsulado em WireGuard (ChaCha20-Poly1305).
8. Em paralelo, dnstap registra a query. Suricata (no host workstation com SPAN/mirror) alerta se a SNI do TLS subsequente bater regra de C2 conhecido.
9. Falco no host alerta se algum processo local fizer conexão para o mesmo destino.
10. Caso a VPN caia: nftables bloqueia toda saída da interface upstream (regra fwmark 51820 sem rota → DROP). Zero vazamento.

7.3 Telemetria ADV7Sec → SIEM local



Padrão preview-first: cada alerta mostra contexto antes de qualquer ação. Resposta automática só com --execute explícito.

Figura 7.2 — Pipeline de telemetria do ADV7Sec. O modo padrão escreve só local (journald + ntfy); SIEM externo é opt-in.

§8 Conclusão e Direcionamento de Carreira

8.1 Resultado esperado

O conjunto OpenBox + ADV7Sec proposto neste documento é, ao mesmo tempo, um **laboratório acadêmico** e uma **resposta defensiva real** para um problema que afeta milhões de famílias brasileiras. O custo de aquisição fica abaixo do preço médio de uma única caixa de TV box pirata. A pilha é inteiramente construída com software livre auditável: `nftables`, `WireGuard`, `dnscrypt-proxy`, `Pi-hole`, `auditd`, `Falco`, `Suricata`, `Zeek`. A documentação é determinística — qualquer alteração no código se reflete automaticamente na documentação Obsidian gerada.

8.2 Lições aprendidas (v0.1 → v0.2 → AVAL01)

- **Iniciar pequeno e versionar cedo.** A v0.1 cobriu o feliz path em Raspberry Pi 4. A v0.2 fez o retarget para um hardware real (RK3229) — e exatamente nesse retarget surgiram os achados sobre BadBox 2.0 que motivaram este estudo de caso.
- **Honestidade técnica vale mais que demo.** Tor para streaming HD *não funciona*; foi documentado em `TOR_STREAMING_CAVEAT.md` em vez de mascarado. Essa postura é central no perfil profissional defensivo.
- **Testes objetivos > "deu certo na minha máquina".** A suíte `validate-stack.sh` com 10 verificações é a diferença entre achar que está seguro e provar que está.

8.3 Direcionamento de carreira

O Brasil tem déficit estrutural de profissionais em segurança defensiva. Operações como a 404 e a PRAEDO mostram que o esforço regulatório existe, mas a defesa do consumidor final — o cidadão que tem um TV box em casa — depende de uma camada de educação técnica que a universidade pode prover. Este projeto sinaliza para o autor uma trilha clara: **Blue Team / SOC / infraestrutura defensiva**, com foco em detecção de ameaças residenciais e análise forense de IoT.

A continuidade natural — para semestres futuros — é o projeto irmão **ADV7ia**, que adiciona uma camada de IA local (LM Studio + OpenHands) ao stack para automatizar a triagem de alertas. Isso conecta Introdução à Computação diretamente às disciplinas mais avançadas de IA, redes e segurança que virão.

POR QUE ISSO IMPORTA

Sair de Introdução à Computação com um projeto real — instalado, testado, documentado, alinhado a uma ameaça concreta no contexto nacional — é diferente de sair com listas de exercícios. É o tipo de evidência que faz diferença no primeiro estágio.

§9 Referências

Cada citação no corpo do texto carrega o marcador correspondente (ex.: ^[1]). Fontes governamentais brasileiras vêm em primeiro lugar, conforme metodologia declarada na §4.1.

9.1 Fontes governamentais brasileiras e oficiais

[1] Ministério das Comunicações (MCom) / Anatel. "Brasil intensifica combate à pirataria digital em 2025, com apreensão milionária e mapeamento de até 8 milhões de usuários clandestinos". Janeiro de 2026.

URL: <https://www.gov.br/mcom/pt-br/noticias/2026/janeiro/brasil-intensifica-combate-a-pirataria-digital-em-2025-com-apreensao-milionaria-e-mapeamento-de-ate-8-milhoes-de-usuarios-clandestinos>

[3] Anatel. "Anatel e Ancine firmam acordo para combater pirataria de conteúdos audiovisuais". 15 de maio de 2025. *Acordo de Cooperação Técnica*.

URL: <https://www.gov.br/anatel/pt-br/assuntos/noticias/anatel-e-ancine-firmam-acordo-para-combater-pirataria-de-conteudos-audiovisuais>

[5] CETIC.br / NIC.br / CGI.br. "TIC Domicílios 2024 — em duas décadas, lares urbanos brasileiros com internet passaram de 13% para 85%". Outubro de 2024.

URL: <https://cetic.br/pt/noticia/em-duas-decadas-proporcao-de-lares-urbanos-brasileiros-com-internet-passou-de-13-para-85-aponta-tic-domicilios-2024/>

PDF Resumo Executivo: https://www.cetic.br/media/docs/publicacoes/2/20250512115624/tic_domicilios_2024_resumo_executivo.pdf

[4] Polícia Federal / Anatel — Operação PRAEDO. "PF e Anatel desarticulam esquema milionário de TV box pirata e gatonet". TELETIME News, 29 de julho de 2025. (Citação direta de ato oficial e participantes.)

URL: <https://teletime.com.br/29/07/2025/pf-e-anatel-desarticulam-esquema-milionario-de-tv-box-pirata-e-gatonet/>

[9] Ministério da Justiça e Segurança Pública (MJSP) — Operação 404, 8ª fase. "Como a Operação 404 bloqueou 535 sites de IPTV e streaming piratas na sua 8ª fase". TargetHD, 27 de novembro de 2024.

URL: <https://www.targethd.net/como-a-operacao-404-bloqueou-535-sites-de-iptv-e-streaming-piratas-na-sua-8a-fase/>

[10] MJSP — Operação 404, 7ª fase. "Operação contra pirataria tira do ar 675 sites e 14 aplicativos de streaming". TELETIME News, 19 de setembro de 2024.

URL: <https://teletime.com.br/19/09/2024/operacao-contra-pirataria-tira-do-ar-sites-e-aplicativos-de-streaming/>

[7] Procon Carioca. "Procon Carioca notifica Google por anúncios de TV box pirata". TELETIME News, 24 de julho de 2025.

URL: <https://teletime.com.br/24/07/2025/procon-carioca-notifica-google-por-anuncios-de-tv-box-pirata>

[8] Procon-SP. "Uso de BTV, UniTV e TV Box pirata: riscos legais e orientações do Procon". Posicionamento oficial, 2025.

URL: <https://onlinedigitalsolucoes.com/uso-de-btv-univtv-e-tv-box-pirata-riscos-legais-e-orientacoes/>

9.2 Fontes internacionais (governo e indústria)

[6] Federal Bureau of Investigation (FBI / IC3). "Public Service Announcement I-060525-PSA — Home Internet Connected Devices Facilitate Criminal Activity". 5 de junho de 2025. (Lista o MXQ Pro 5G entre os dispositivos BadBox 2.0 confirmados.)

URL: <https://www.ic3.gov/PSA/2025/PSA250605>

[2] HUMAN Security — Satori Threat Intelligence Team. "Satori Threat Intelligence Disruption: BADBOX 2.0 Targets Consumer Devices with Multiple Fraud Schemes". Março de 2025. (Fonte da estatística "> 1/3 das infecções estão no Brasil".)

URL: <https://www.humansecurity.com/learn/blog/satori-threat-intelligence-disruption-badbox-2-0/>

[11] HUMAN Security. "HUMAN Exposes BADBOX 2.0 Scheme Infecting 1 Million Off-Brand Android Open Source Project Devices". Sala de imprensa, 2025.

URL: <https://www.humansecurity.com/newsroom/human-exposes-badbox-2-0-scheme/>

[12] Electronic Frontier Foundation (EFF). "FBI Warning on IoT Devices: How to Tell If You Are Impacted". Junho de 2025.

URL: <https://www.eff.org/deeplinks/2025/06/fbi-warning-iot-devices-how-tell-if-you-are-impacted>

9.3 Fontes acadêmicas e modelo da disciplina

[15] UniCEUB — Disciplina Introdução à Computação. Documento "[IC]AV01-A.pdf" — Avaliação 01: Estudo de Caso, Pitch e Projeto Técnico (rubrica oficial). Brasília, 2026.

Fornecido pela disciplina; arquivo local: ~/Downloads/[IC]AV01-A.pdf

9.4 Pesquisa e código próprios (AOPS)

[14] Pollazzon Soterio, A. O. (AOPS). "Inside the MXQ Pro 5G 4K R2390 — Rockchip RK3229 com firmware comprometido".

Pesquisa interna ("compass artifact"), abril de 2026.

Caminho local: ~/Downloads/compass_artifact_wf-562a9f40-b72e-40e3-b1d7-e800f8b32ae7_text_markdown.md

[13] AOPS. "RK3229_THREAT_RESEARCH — análise de ameaças do hardware Rockchip RK322x". Documento interno, abril de 2026.

~/ObsidianAgent/Projects/IC01-aops/OpenBox0.1v/docs/security/RK3229_THREAT_RESEARCH.md

[16] AOPS. "ADV7Sec 1.0v — control plane IPS/IDS Linux-first detection-only".

~/ObsidianAgent/Projects/IC01-aops/IPS_IDS/ADV7Sec_1.0v.py

[17] AOPS. "OpenBox v0.2.0 — caixa de borda residencial RK3229 (WireGuard + DNS cifrado + nftables kill switch)".

~/ObsidianAgent/Projects/IC01-aops/OpenBox0.1v/

[18] AOPS. "ADV7Box — entrega consolidada AV01-A (referência de estilo desta entrega)".

~/ObsidianAgent/Projects/IC01-aops/OpenBox0.1v/ADV7Box/

§10 Apêndice — Evidências de Desenvolvimento

10.1 Estrutura de diretórios

```
~/ObsidianAgent/Projects/IC01-aops/
├── OpenBox0.1v/                                # Pilar A – código do edge router (versionado)
│   ├── install.sh                             # Orquestrador faseado
│   ├── install.d/                             # 10 fases idempotentes (00-base ... 09-validate)
│   ├── etc/                                   # Configs (nftables, wg, dnscrypt, tor, monit, caddy)
│   ├── systemd/                              # Units e timers (watchdogs)
│   ├── tests/                                # ci-syntax, validate-stack, vault validation
│   ├── docs/                                 # CASE_STUDY, THREAT_MODEL, RUNBOOK, security/RK3229
│   ├── vault/                                # Obsidian vault (auto-gerado)
│   ├── CHANGELOG.md, VERSION
│   └── ADV7Box/                              # Entrega irmã AV01-A (HTML+PDF)
├── IPS_IDS/                                   # Pilar B – ADV7Sec (control plane Python)
│   ├── ADV7Sec_1.0v.py                       # Entry point
│   ├── adv7sec_1_0/                          # Pacote: 23 módulos (audit, install, analyze, ...)
│   ├── tests/                                # Unit + integration tests
│   └── docs/                                 # PHASE2_TUNING, ADV7Sec_1.0_AUDIT
├── ADV7ia/                                    # Roadmap futuro: LLM local + OpenHands (ADV7Sec + IA)
└── AVAL01-IC/                                # ESTA ENTREGA
    ├── AVAL01-IC.html                        # Fonte canônica
    ├── AVAL01-IC.pdf                         # Renderização Chromium
    ├── AVAL01-IC.docx                        # Conversão Pandoc
    ├── README.md, CLAUDE.md
    ├── build.sh                             # Pipeline html → pdf + docx
    └── assets/
        └── sources.json                      # Bibliografia rastreável (todas as 18 referências)
```

10.2 Como reproduzir esta entrega

```
cd ~/ObsidianAgent/Projects/IC01-aops/AVAL01-IC

# Build
bash build.sh

# Verificar integridade dos links
grep -oE 'https?://[^\<> ]+' AVAL01-IC.html | sort -u | \
  while read u; do
    code=$(curl -s -o /dev/null -w '%{http_code}' -I -L --max-time 10 "$u")
    printf '%s %s\n' "$code" "$u"
  done

# Hashes (atualizam após cada build)
sha256sum AVAL01-IC.{html,pdf,docx}
```

10.3 Mapeamento rubrica AVAL01 → seção

Critério (rubrica oficial AVAL01)	Seção atendida	Evidência
Estudo de Caso — diagnóstico de cenário real	§2 + §4	Contexto BR + caso MXQ Pro 4k com fontes governamentais
Demanda de hardware / software / redes / APIs / IA	§6 + §7	Tabela 6.1 (HW), Lista 6.2 (SW), Lista 6.3 (rede), Diagrama 7.1
Qualidade Técnica — arquitetura justificada	§3, §5, §7	Timeline com decisões, ADV7Sec sensores, diagramas SVG
Uso exemplar de ferramentas externas	§10	Repositórios versionados (OpenBox, ADV7Sec, ADV7Box) + sources.json
Estrutura do PDF — diagramas + escrita técnica	§3.1, §4.2, §7.1, §7.3	5 figuras SVG inline próprias + escrita didática humanizada

10.4 Hashes dos artefatos

Calculados após o último build. Servem como prova de integridade da entrega na sala online — qualquer modificação posterior alterará o hash e poderá ser auditada.

```
sha256(AVAL01-IC.html) = 9e36d9af6a9e6ea84ea336fa333a32ca8d615117e0d3630dcdbd9adcdf67cd7e2
sha256(AVAL01-IC.pdf) = 6596fbe9cbfcc28e5db7157a094bce0b340ca683323b93308ff564f880e8a891
sha256(AVAL01-IC.docx) = (gerar com pandoc-cli - ver §10.2 / build.sh)
# Hashes correspondem ao último build registrado.
# Cada execução de bash build.sh gera novos hashes - para auditoria pós-entrega,
# usar git tag ou registro manual da versão entregue na sala online.
```

10.5 Pendências e itens em aberto

- O ADV7Sec roda hoje em modo `preview-first`. Ativar `--execute` em produção exige checklist adicional ainda a redigir.
- Roadmap ADV7ia (integração com LLM local) está fora do escopo desta AV — será abordado em entregas futuras de outras disciplinas.
- O hardware RK3229 tem ports comunitários LibreELEC/Armbian instáveis em alguns lotes (Wi-Fi SSV6051P sem driver mainline) — o instalador detecta e aborta com mensagem clara, mas a recomendação prática é usar Raspberry Pi 4 quando disponível.